

THE AI AGENT GOVERNANCE GAP

Why AI Agents Are Running Wild, and How to Regain Control

As enterprises race to deploy autonomous agents, a dangerous governance gap has emerged. This white paper identifies the architectural root cause of this gap and provides concrete steps for identity, authorization, and control required to secure AI agents at scale.



The Inevitable Crisis

In December, [a new report from Cybersecurity Insiders and Saviynt](#) confirmed the governance crisis unfolding across enterprise AI deployments. The numbers read like validation of warnings nobody heeded: 71% of large enterprises have deployed AI agents with direct access to core business systems (SAP, Salesforce, data warehouses, payment processors, ...) yet only 16% effectively govern that access.

71%

Access Without Control

71% of large enterprises have deployed AI agents with direct access to core business systems yet only 16% effectively govern that access.

This wasn't a surprise. It was inevitable.

At organizations, like Gravitee, that work at the intersection of API management, identity governance, and emerging autonomous systems, the pattern has been visible for months. It is reflected across modern proofs-of-concept and technical architecture discussions, signaling a broader industry shift toward integrated security models.

Gravitee surveyed 919 executives and practitioners and published [the State of Agent Security report](#). They found that 88% of organizations confirmed or suspected security incidents this year. Organizations deploy AI agents at breakneck speed, treat identity and access management as an afterthought, and then scramble to bolt on governance frameworks that were designed for human workflows, not machine-speed autonomous systems.



AI agents are already deployed at meaningful scale

Cybersecurity Insiders' report surveyed 235 Chief Information Security Officers (CISO) across the world, all leading organizations with 5,000+ employees. What they revealed is straightforward and damning: AI agents have outpaced the identity and access frameworks designed to control them. These autonomous systems operate at machine speed, chain actions across multiple systems, accumulate permissions quietly, and leave behind logs that security teams struggle to parse. Meanwhile, the tools designed to govern them, APIM and IAM platforms were built for human users and traditional service accounts.

The result is organizational blind spots that compound daily. And it was entirely foreseeable given the trajectory of both AI adoption and governance infrastructure.

The Numbers Confirm the Pattern

Start with visibility. 92% of organizations lack full visibility into their AI identities, and 95% doubt they could detect or contain misuse if it occurred. This isn't theoretical anxiety. 47% of surveyed CISOs have already observed AI agents exhibit unintended or unauthorized behavior in their environments. A third of respondents dealt with actual security incidents or near-misses in the past year.

The governance gaps are equally stark. Only 17% of organizations govern even half of their AI identities using the same rigor applied to human users. Just 5% feel prepared to contain a compromised AI agent. **86% don't enforce access policies for AI identities at all.**

92%

Lack Full Visibility

95%

Doubt Detection

86%

Don't Enforce Access

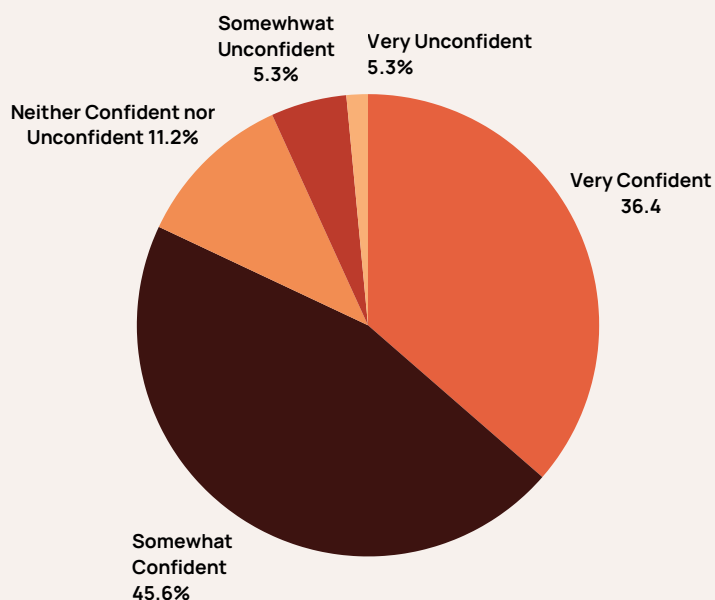
What's striking is not that organizations lack awareness of the risk. Rather, they lack the architectural foundation to address it. 60% still rely on legacy authentication patterns, session management, password policies, designed for human workflows. These approaches fundamentally misalign with how AI agents operate. Agents need token lifecycle management, scope-limited and fine-grained authorization, runtime enforcement, and API-first controls. They need governance that happens at machine speed, not through manual, human-paced approval chains.

💡 **Only 25% of organizations currently use AI-specific monitoring controls**

This was predictable because the underlying problem is architectural, not operational. Organizations built their identity infrastructure for human users. When autonomous agents arrived, they tried to fit machines into human-shaped security models. The friction was inevitable.

Gravitee's latest survey highlights a confidence gap in AI leadership: 82% of executives report high confidence in their AI security policies, yet only 47.1% of organizations' AI agents are actually monitored or secured. There is a massive disconnect between policy and implementation. Leaders are confident in their 'security models' while failing to realize those models are meant for human workflows and not autonomous agents.

Confidence in AI Security Policies



Source: Gravitee The State of AI Agent Security Report 2026

Shadow AI: The Visibility Problem Nobody Solved

💡 **Friction drives shadow adoption; if your approved tools are slow, teams will bypass them**

Cybersecurity Insiders' report identifies another critical failure: shadow AI proliferation. 75% of organizations have discovered unsanctioned AI tools already running inside their environments. These tools often come embedded with credentials or elevated system access that security teams don't even know exists.

14.4%

The Approval Gap

Only 14.4% of organizations have achieved full IT and security approval for their entire agent fleet.

This isn't rogue employees acting maliciously. It's rational actors responding to organizational friction. Shadow AI tools like ChatGPT, Claude, and open-source LLMs are frictionless. They integrate in days, not months. They deliver immediate productivity gains. When internal tools require lengthy procurement, security review, and compliance vetting, the decision calculus for employees shifts toward external alternatives, and mechanically organizational risk grows proportionally.

Gravitee's research reinforces this pattern, revealing a staggering approval gap: only 14.4% of organizations have achieved full IT and security approval for their entire agent fleet. The vast majority of agents are instead deployed at the departmental or team level, frequently bypassing official vetting entirely to gain immediate productivity.

The problem is architectural. The undetected activity of autonomous agents operating on production data compromises crucial compliance and audit trails before the security team can even become aware of their existence.

This outcome was entirely predictable given that organizations lacked the foundational governance infrastructure needed to support frictionless, compliant AI adoption.

“

Business leaders want to move quickly with AI, but with different tools, different models, different rules, it can be hard to have a clear picture of where data is going or how decisions are being made.

Jane Wakefield, Technology Journalist
The Human In The Loop Podcast, Episode 1

The Identity Governance Framework That's Missing

Here's where the report intersects with a broader evolution happening in the identity and security landscape. Previous analysis regarding the convergence of MCP, OAuth 2.1, and fine-grained authorization established that modern AI infrastructure requires a unified security architecture capable of moving beyond coarse-grained token scopes. The same principle applies here at enterprise scale. AI agents require an authorization framework that understands context, relationships, and the specific operations agents are attempting, not just broad role-based permissions.

The CISO report confirms this gap. When CISOs were asked where they'd invest if budget weren't a constraint, 73% prioritized API and workload identity discovery and inventory. Another 68% focused on continuous monitoring and posture analytics. Both reveal a hunger for visibility and control that existing tools simply don't provide.

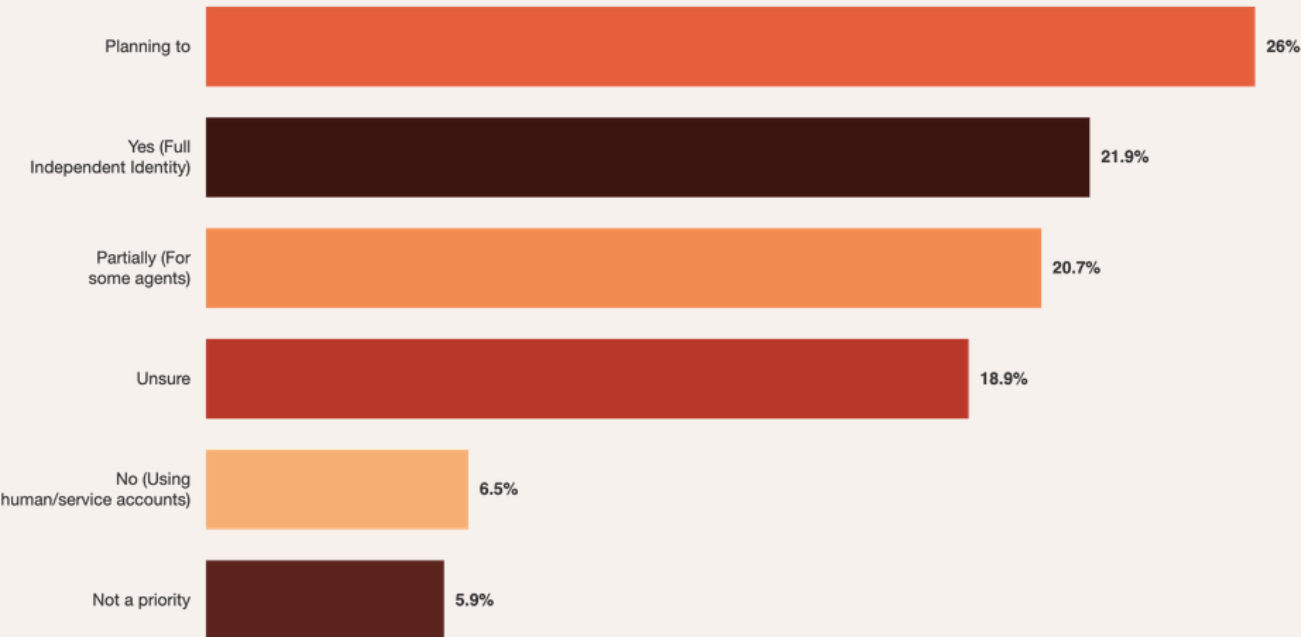
<22%

Missing Identity Layer

22% of enterprises treat AI agents as first-class security identities

The priority placed on identity discovery highlights a systemic governance deficit. Gravitee's data reveals that fewer than 22% of enterprises treat AI agents as first-class security identities. By failing to de-couple agent identities from their parent systems, organizations are creating a 'shadow' layer of execution where agents inherit broad permissions by default. This architectural misalignment makes it impossible to enforce the machine-speed, fine-grained controls required for secure AI orchestration.

Treatment of AI Agents as independent, identity-bearing entities within the security model



The convergence is becoming clear; organizations need an identity layer that treats every AI agent as a first-class identity, with:



Structured identity provisioning - Clear ownership, defined lifecycle, and explicit authorization for each agent. Not inherited credentials or default permissions.



Scope-limited authorization - Tokens bound to specific resources, operations, and time windows, what RFC 8707 calls Resource Indicators, now mandated since MCP's June 2025 specification revision. A token issued for one service cannot be misused at another.



Contextual authorization decisions - Fine-grained authorization that evaluates not just who is requesting access, but what they're requesting and why. This is the domain of relationship-based access control (ReBAC) and attribute-based access control (ABAC).



Continuous monitoring and posture analytics - Real-time visibility into what every agent is doing, what permissions it holds, whether it's exhibiting drift or anomalous behavior, and whether it can still justify its access.

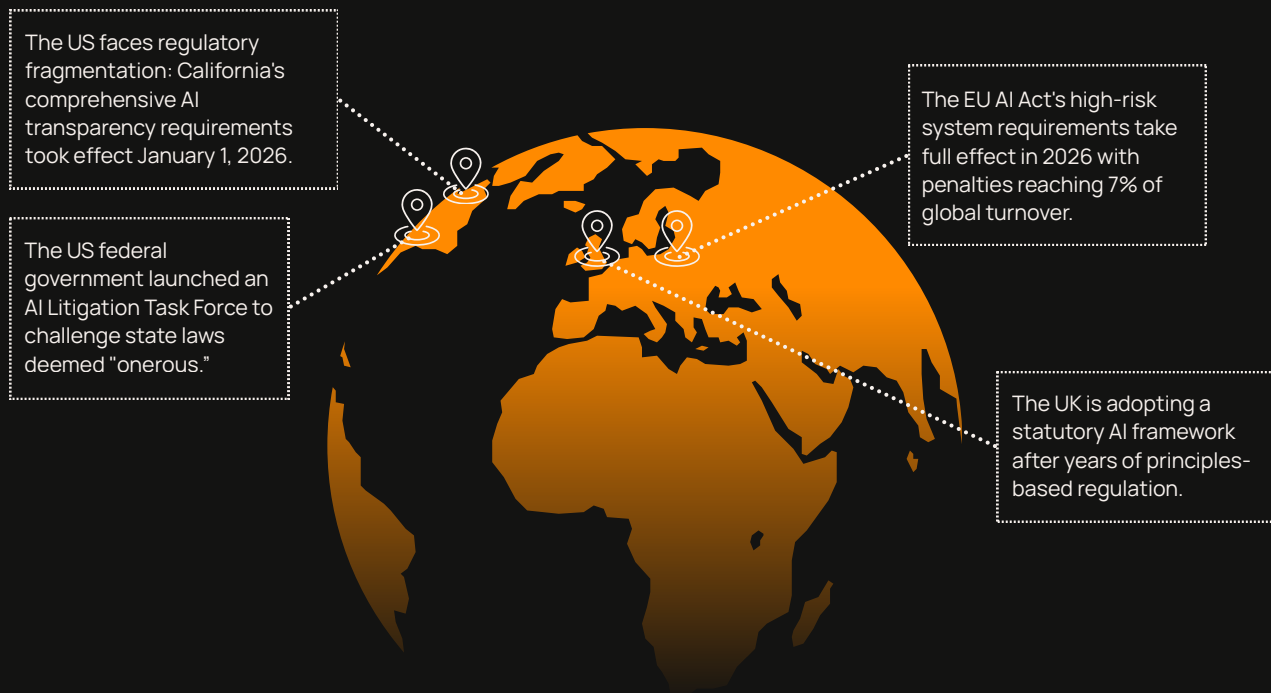


Audit trails that survive forensic scrutiny - Every authorization decision must be traceable, timestamped, and auditable for compliance and incident response.

This is not revolutionary. It's the natural evolution of identity governance applied to autonomous systems operating at machine speed. And it was predictable that organizations deploying AI without this framework would face governance crises.

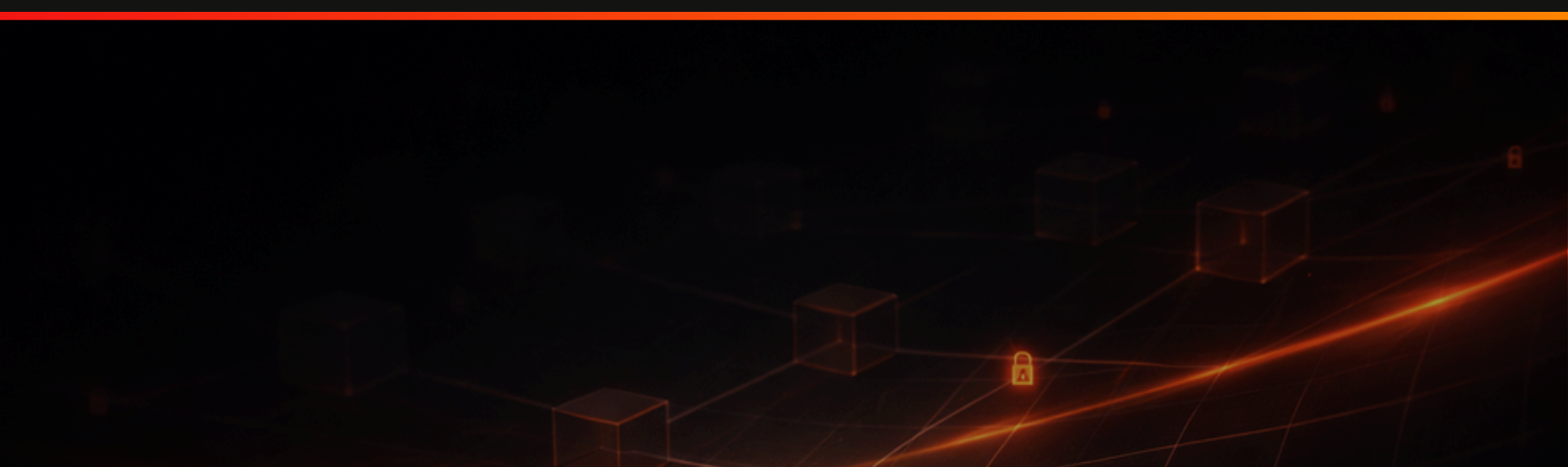
The Regulatory Urgency

Regulatory pressure is now simultaneous and conflicting across major markets.



Organizations can no longer defer AI governance, yet Gravitee's data reveals a dangerous "wait-and-see" paradox. While 84% of CISOs worry about the business risk of ungoverned AI, there is a profound disconnect at the board level: 69.2% of executives believe current regulations are already sufficient to mitigate agentic risk. This regulatory comfort is masking a significant funding gap.

Despite the intersecting compliance obligations and organizational anxiety, security spending is failing to keep pace with adoption. In fact, the investment landscape has hit a stalemate: nearly as many organizations expect their AI agent security budgets to decrease (41.6%) as those who expect an increase (42.4%) over the next 12 months. This stagnation suggests that while "compliance" boxes are being checked to satisfy regulators, the actual technical implementation of agent security is being left underfunded and exposed.



What Organizations Can Do Now

The path forward requires three immediate actions:



Inventory and visibility. Organizations must discover every AI identity already deployed, sanctioned and unsanctioned, and map its access footprint. This includes shadow AI tools, embedded credentials, service accounts, and delegated agents. Seventy-three percent of CISOs want to invest here, it's the highest priority.

Governance primitives. Establish clear identity lifecycle management for AI agents. Define who owns each agent, what permissions it holds, what operations it can perform, and when that access expires or requires renewal. Treat agents as first-class identities, not afterthoughts or configurations hidden in environment variables.

Unified authorization. Move from coarse-grained role-based access control toward fine-grained authorization that understands context, relationships, and intent. This means integrating identity governance with policy engines that can evaluate agent requests in real time against zero trust principles.



Governance Without Friction: Building the Unified AI Identity Layer

Organizations that take this seriously are converging on a unified stack: OAuth 2.1 for token security and scope-limiting, fine-grained authorization for contextual decision-making, and comprehensive identity governance across human and non-human identities. This is not theoretical. The infrastructure exists today and the CISO report's central insight cuts to the heart of the problem: governance frameworks that create friction drive shadow AI. Organizations can't secure what they can't see, and can't govern what they can't access quickly.

This is where tooling matters. The latest capabilities of the Gravitee platform across API management, identity governance, and AI infrastructure platforms demonstrate how to solve this paradox: enabling frictionless, compliant AI adoption while maintaining enterprise-grade governance.

For Large Language Models

Gravitee API gateways can now proxy all LLM access through a unified control point. Rather than agents integrating directly with OpenAI, Bedrock, Gemini, or other providers, bypassing governance entirely, they proxy through the gateway. This delivers immediate governance benefits:

Token-based rate limiting

Count and limit by token consumption, not just request volume. Organizations can protect budgets and prevent runaway costs in real time.

Complete Observability

Track token consumption, model usage, costs, and latency across all LLM invocations in one unified system.

Dynamic Model Routing

Route requests across multiple LLM providers and models based on policy, application context, or real-time cost optimization. Avoid vendor lock-in.

Content classification and guardrails.

Apply AI-powered analysis to detect PII, PCI sensitive data, prompt injection attacks, and jailbreak attempts before they reach external LLMs. Organizations can ensure proprietary data doesn't leak into public models.

Authorization & authentication at the gateway

Enforce who can access which models with what scope, governed by OAuth 2.1 and fine-grained access control.

This solves the shadow AI problem by making compliant LLM access faster than non-compliant alternatives.

For MCP Servers and Agent Communication

The emerging ecosystem of MCP requires native governance support. Rather than treating MCP as point-to-point integrations between agents and servers, platforms should provide a central governance layer:

Protocol-native proxy

The gateway introspects MCP payloads to understand which methods, tools, and prompts are being invoked. This isn't generic REST proxying, it understands protocol semantics.

Granular access control policies

Define access controls that determine which agents can access which tools, which prompts, which resources. Prevent agents from discovering or invoking capabilities they shouldn't.

Authorization specification compliance

Implement the MCP authorization standard, handling token validation and authorization server redirects. Move this responsibility from individual servers to the central gateway.

Agent discovery and catalog

Provide a central registry of all AI agents deployed across the organization. Visibility becomes the foundation for governance.

This solves the "we don't know what's running" problem by creating unified discovery and governance.

For Fine-Grained Authorization

Organizations should implement relationship-based and attribute-based access control for all AI identities. This means:

- Structured ownership and lifecycle management for each agent
- Scope-limited tokens bound to resources, operations, and time windows
- Contextual authorization decisions that evaluate intent and risk
- Continuous monitoring for drift and anomalous behavior
- Complete audit trails for forensic and compliance purposes

This transforms AI from a risk category into a governable capability.

For REST API Integration

Any REST API can be exposed as an MCP server, enabling AI agents to discover and invoke capabilities using standardized protocols. No agent lock-in. No proprietary integrations. Standards-based. Governed.

The Combined Effect

When these capabilities are deployed in concert, LLM proxying for language models, MCP proxying for agent-to-agent communication, fine-grained authorization for identity governance, and centralized agent discovery, organizations create an integrated AI governance architecture. Shadow AI still exists, but now there's a frictionless, compliant alternative. Agents can access the LLMs they need, the tools they require, and the APIs they're authorized for, all through a single governance layer that tracks every access, enforces every policy, and maintains complete audit trails.

The cost of compliance becomes lower than the cost of shadow AI. Organizations win.

